

NIST SP 800-53 Rev 5 control IA-5.15 (GSA-approved Products and Services) is assessed by examining, interviewing, and testing: IA-5.15 · GSA-approved Products and Services Control Statement: Use only General Services Administration-approved products and services for identity, credential, and access management. Supplemental Guidance: Use only General Services Administration-approved products and services for identity, credential, and access management. General Services Administration (GSA)-approved products and services are products and services that have been approved through the GSA conformance program, where applica

NIST SP 800-53 Rev 5 control IA-9 (Service Identification and Authentication) is defined as follows: IA-9 · Service Identification and Authentication Control Statement: Uniquely identify and authenticate [organization-defined parameter] before establishing communications with devices, users, or other services or applications. Supplemental Guidance: Uniquely identify and authenticate [organization-defined parameter] before establishing communications with devices, users, or other services or applications. Services that may require identification and authentication include web applications using digital certificates or services or applications that query a database. Identification and authent

NIST SP 800-171 Rev 3 control 03.05.05 (03.05.05 Identifier Management) falls under the Identification and Authentication family. Control Statement: SR-03.05.05.a Receive authorization from organizational personnel or roles to assign an individual, group, role, service, or device identifier. SR-03.05.05.b Select and assign an identifier that identifies an individual, group, role, service, or device. SR-03.05.05.c Prevent the reuse of identifiers for [organization-defined parameter]. SR-03.05.05.d Manage individual identifiers by uniquely identifying each individual as [organization-defined parameter]. Supplemental Guidance: Identifiers are provided for users, processes acting on behalf of users, and devices. Prohibiting the reuse of identifiers prevents the assignment of previously used individual, group, role, service, or device identifiers to different individuals, groups, roles, services, or devices. Characteristics that identify the status of individuals include contractors, foreign nationals, and non-organizational users. Identifying the status of individuals by these characteristics pro

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: 2) Contains a string of characters that does not include the user-s account name or full name. Identification and Authentication 3.5.12 Authenticator Management a. Verify the identity of the individual, group, role, service, or device receiving the authenticator as part of the initial authenticator distribution. b. Establish initial authenticator content for any authenticators issued by the organization. c. Establish and implement administrative procedures for initial authenticator distribution; for lost, compromised, or damaged authenticators; and for revoking authenticators. d. Change default authenticators at first use. e. Change or refresh authenticators [Assignment: organization-defined frequency] (03.05.12.e.01) or when the following events occur: [Assignment: organizatio

Under the FedRAMP Moderate baseline, IA-8 (IA-8 Identification and Authentication (Non-organizational Users)): FedRAMP Moderate Baseline · IA-8 · Identification and Authentication (Non-organizational Users) Control Statement: Uniquely identify and authenticate non-organizational users or processes acting on behalf of non-organizational users. Supplemental Guidance: Uniquely identify and authenticate non-organizational users or processes acting on behalf of non-organizational users. Non-organizational users include system users other than organizational users explicitly covered by [IA-2](#ia-2) . Non-or

NIST SP 800-171 Rev 3 control 03.05.12 (03.05.12 Authenticator Management) requires organizations to implement the following: Control Statement: SR-03.05.12.a Verify the identity of the individual, group, role, service, or device receiving the authenticator as part of the initial authenticator distribution. SR-03.05.12.b Establish initial authenticator content for any authenticators issued by the organization. SR-03.05.12.c Establish and implement administrative procedures for initial authenticator distribution; for lost, compromised, or damaged authenticators; and for revoking authenticators. SR-03.05.12.d Change default authenticators at first use. SR-03.05.12.e Change or refresh authenticators [organization-defined parameter] or when the following events occur: [organization-defined parameter]. SR-03.05.12.f Protect authenticator content from unauthorized disclosure and modification. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.05.12.

Under the FedRAMP High baseline, IA-3 (IA-3 Device Identification and Authentication): FedRAMP High Baseline · IA-3 · Device Identification and Authentication Control Statement: Uniquely identify and authenticate [organization-defined parameter] before establishing a [organization-defined parameter] connection. Supplemental Guidance: Uniquely identify and authenticate [organization-defined parameter] before establishing a [organization-defined parameter] connection. Devices that require unique device-to-device identification and authentication are defined by type, device, or a c

NIST SP 800-53 Rev 5 control IA-12.2 (Identity Evidence): IA-12.2 · Identity Evidence Control Statement: Require evidence of individual identification be presented to the registration authority. Supplemental Guidance: Require evidence of individual identification be presented to the registration authority. Identity evidence, such as documentary evidence or a combination of documents and biometrics, reduces the likelihood of individuals using fraudulent

NIST SP 800-53 Rev 5 control IA-8.6 (Disassociability): IA-8.6 · Disassociability Control Statement: Implement the following measures to disassociate user attributes or identifier assertion relationships among individuals, credential service providers, and relying parties: [organization-defined parameter]. Supplemental Guidance: Implement the following measures to disassociate user attributes or identifier assertion relationships among individuals, c

NIST SP 800-171 Rev 3 control 03.05.02 (03.05.02 Device Identification and Authentication) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Identification and Authentication (IA) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

and e. Terminate session and network connections when nonlocal maintenance is completed. Discussion: Nonlocal maintenance and diagnostic activities are conducted by individuals who communicate through either an external or internal network. Local maintenance and diagnostic activities are carried out by individuals who are physically present at the system location and not communicating across a network connection. Authentication techniques used to establish nonlocal maintenance and diagnostic sessions reflect the network access requirements in IA-2. Strong authentication requires authenticators that are resistant to replay attacks and employ multi-factor authentication. Strong authenticators include PKI where certificates are stored on a token protected by a password, passphrase, or biometric. Enforcing requirements in MA-4 is accomplished, in part, by other controls. [SP 800-63B] provides additional guidance on strong authentication and authenticators. Related Controls: AC-2, AC-3, AC-6, AC-17, AU-2, AU-3, IA-2, IA-4, IA-5, IA-8, MA-2, MA-5, PL-2,

NIST SP 800-53 Rev 5 control IA-2.13 (Out-of-band Authentication) is assessed by examining, interviewing, and testing: IA-2.13 · Out-of-band Authentication Control Statement: Implement the following out-of-band authentication mechanisms under [organization-defined parameter]: [organization-defined parameter]. Supplemental Guidance: Implement the following out-of-band authentication mechanisms under [organization-defined parameter]: [organization-defined parameter]. Out-of-band authentication refers to the use of two separate communication paths to identify and authenticate users or devices to an information sy

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Related Controls: IA-03 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.05.02 [Assignment: organization- defined devices or types of devices] all devices for identification, where feasible for authentication, and document when not feasible Identification and Authentication 3.5.5 Identifier Management a. Receive authorization from organizational personnel or roles to assign an individual, group, role, service, or device identifier. b. Select and assign an identifier that identifies an individual, group, role, service, or device. c. Prevent the reuse of identifiers for [Assignment: organization-defined time period] (03.05.05.c). d. Manage individual identifiers by uniquely identifying each individual as [Assignment: organization-defined characteristic identifying

NIST SP 800-53 Rev 5 control IA-3.1 (Cryptographic Bidirectional Authentication) summarizes the requirements for this control: IA-3.1 · Cryptographic Bidirectional Authentication Control Statement: Authenticate [organization-defined parameter] before establishing [organization-defined parameter] connection using bidirectional authentication that is cryptographically based.

Supplemental Guidance: Authenticate [organization-defined parameter] before establishing [organization-defined parameter] connection using bidirectional authentication that is cryptographically based. A local connection is a connection with a device

NIST SP 800-53 Rev 5 control IA-2.12 (Acceptance of PIV Credentials) is assessed by examining, interviewing, and testing: IA-2.12 · Acceptance of PIV Credentials Control Statement: Accept and electronically verify Personal Identity Verification-compliant credentials. Supplemental Guidance: Accept and electronically verify Personal Identity Verification-compliant credentials. Acceptance of Personal Identity Verification (PIV)-compliant credentials applies to organizations implementing logical access control and physical access control systems. PIV-compliant credentials are those credentials issued by federal agency

Under the FedRAMP High baseline, IA-2.6 (IA-2.6 Access to Accounts ·separate Device): FedRAMP High Baseline · IA-2.6 · Access to Accounts ·separate Device Control Statement: Implement multi-factor authentication for [organization-defined parameter] access to [organization-defined parameter] such that: (a) One of the factors is provided by a device separate from the system gaining access; and (b) The device meets [organization-defined parameter]. Supplemental Guidance: Implement multi-factor authentication for [organization-defined parameter] access to [organization-defined parameter]

Under the FedRAMP Low baseline, IA-11 (IA-11 Re-authentication): FedRAMP Low Baseline · IA-11 · Re-authentication Control Statement: Require users to re-authenticate when [organization-defined parameter]. Supplemental Guidance: Require users to re-authenticate when [organization-defined parameter]. In addition to the re-authentication requirements associated with device locks, organizations may require re-authentication of individuals in certain situations, including when roles, authenticators or credentials change, when security categories of systems change

NIST SP 800-171 Rev 3 control 03.05.01 (03.05.01 User Identification and Authentication) is assessed by examining the following: Assessment Objectives: - system users are uniquely identified. - system users are authenticated. - processes acting on behalf of users are associated with uniquely identified and authenticated system users. - users are reauthenticated when [organization-defined parameter] .

NIST SP 800-53 Rev 5 control IA-8.5 (Acceptance of PIV-I Credentials) summarizes the requirements for this control: IA-8.5 · Acceptance of PIV-I Credentials Control Statement: Accept and verify federated or PKI credentials that meet [organization-defined parameter]. Supplemental Guidance: Accept and verify federated or PKI credentials that meet [organization-defined parameter]. Acceptance of PIV-I credentials can be implemented by PIV, PIV-I, and other commercial or external identity providers. The acceptance and verification of PIV-I-compliant credentials apply to both logical and physical access controls

NIST SP 800-53 Rev 5 control IA-11 (Re-authentication) summarizes the requirements for this control: IA-11 · Re-authentication Control Statement: Require users to re-authenticate when [organization-defined parameter]. Supplemental Guidance: Require users to re-authenticate when [organization-defined parameter]. In addition to the re-authentication requirements associated with device locks, organizations may require re-authentication of individuals in certain situations, including when roles, authenticators or credentials change, when security categories of systems change, when the execution of

Under the FedRAMP Moderate baseline, IA-12.5 (IA-12.5 Address Confirmation): FedRAMP Moderate Baseline · IA-12.5 · Address Confirmation Control Statement: Require that a [organization-defined parameter] be delivered through an out-of-band channel to verify the user's address (physical or digital) of record. Supplemental Guidance: Require that a [organization-defined parameter] be delivered through an out-of-band channel to verify the user's address (physical or digital) of record. To make it more difficult for adversaries to pose as legitimate users during the identity process

NIST SP 800-171 Rev 3 control 03.05.07 (03.05.07 Password Management) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Identification and Authentication (IA) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

From the NIST SP 800-172 Rev 3 Final Public Draft: ADVERSARY EFFECTS 1137 Preclude (Preempt), Impede (Exert) REFERENCES Source Control: IA-05(13) 03.0 5.06E Identity Proofing a. Identity proof users that require accounts for logical access to systems based on appropriate identity assurance level requirements as specified in applicable standards and guidelines. b. Resolve user identities to a unique individual. c. Collect, validate, and verify identity evidence. DISCUSSION Identity proofing is the process of collecting, validating, and verifying user identity information to establish credentials for accessing a system. Identity proofing is intended to mitigate threats to the registration of users and the establishment of their accounts. Organizations may be subject to laws, Executive Orders, directives, regulations, or poli

NIST SP 800-53 Rev 5 control IA-8 (Identification and Authentication (Non-organizational Users)) is assessed by examining, interviewing, and testing: IA-8 · Identification and Authentication (Non-organizational Users) Control Statement: Uniquely identify and authenticate non-organizational users or processes acting on behalf of non-organizational users. Supplemental Guidance: Uniquely identify and authenticate non-organizational users or processes acting on behalf of non-organizational users. Non-organizational users include system users other than organizational users explicitly covered by [IA-2](#ia-2) . Non-organizational users are uniqu

Under the FedRAMP Low baseline, IA-2.12 (IA-2.12 Acceptance of PIV Credentials): FedRAMP Low Baseline · IA-2.12 · Acceptance of PIV Credentials Control Statement: Accept and electronically verify Personal Identity Verification-compliant credentials. Supplemental Guidance: Accept and electronically verify Personal Identity Verification-compliant credentials. Acceptance of Personal Identity Verification (PIV)-compliant credentials applies to organizations implementing logical access control and physical access control systems. PIV-compliant credentials are those credentials

NIST SP 800-53 Rev 5 control IA-9 (Service Identification and Authentication) summarizes the requirements for this control: IA-9 · Service Identification and Authentication Control Statement: Uniquely identify and authenticate [organization-defined parameter] before establishing communications with devices, users, or other services or applications. Supplemental Guidance: Uniquely identify and authenticate [organization-defined parameter] before establishing communications with devices, users, or other services or applications. Services that may require identification and authentication include web applications usin

NIST SP 800-53 Rev 5 control IA-12.4 (In-person Validation and Verification) is defined as follows: IA-12.4 · In-person Validation and Verification Control Statement: Require that the validation and verification of identity evidence be conducted in person before a designated registration authority. Supplemental Guidance: Require that the validation and verification of identity evidence be conducted in person before a designated registration authority. In-person proofing reduces the likelihood of fraudulent credentials being issued because it requires the physical presence of individuals, the presentation of physical identity documents, and actual face-to-face interactions with designated r

NIST SP 800-53 Rev 5 control IA-3.3 (Dynamic Address Allocation) is defined as follows: IA-3.3 · Dynamic Address Allocation Control Statement: (a) Where addresses are allocated dynamically, standardize dynamic address allocation lease information and the lease duration assigned to devices in accordance with [organization-defined parameter] ; and (b) Audit lease information when assigned to a device. Supplemental Guidance: (a) Where addresses are allocated dynamically, standardize dynamic address allocation lease information and the lease duration assigned to devices in accordance with [organization-defined parameter] ; and (b) Audit lease information when assigned to a device.

Under the FedRAMP Low baseline, IA-2.8 (IA-2.8 Access to Accounts · Replay Resistant): FedRAMP Low Baseline · IA-2.8 · Access to Accounts · Replay Resistant Control Statement: Implement replay-resistant authentication mechanisms for access to [organization-defined parameter]. Supplemental Guidance: Implement replay-resistant authentication mechanisms for access to [organization-defined parameter]. Authentication processes resist replay attacks if it is impractical to achieve successful authentications by replaying previous authentication messages. Replay-resistant techniques inc

Under the FedRAMP Moderate baseline, IA-2 (IA-2 Identification and Authentication (Organizational Users)): FedRAMP Moderate Baseline · IA-2 · Identification and Authentication (Organizational Users) Control Statement: Uniquely identify and authenticate organizational users and associate that unique identification with processes acting on behalf of those users. Supplemental Guidance: Uniquely identify and authenticate organizational users and associate that unique identification with processes acting on behalf of those users. Organizations can satisfy the identification and authentication requiremen

NIST SP 800-171 Rev 3 control 03.05.05 (03.05.05 Identifier Management) requires organizations to implement the following: Control Statement: SR-03.05.05.a Receive authorization from organizational personnel or roles to assign an individual, group, role, service, or device identifier. SR-03.05.05.b Select and assign an identifier that identifies an individual, group, role, service, or device. SR-03.05.05.c Prevent the reuse of identifiers for [organization-defined parameter]. SR-03.05.05.d Manage individual identifiers by uniquely identifying each individual as [organization-defined parameter]. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.05.05.

IA-13 · Identity Providers and Authorization Servers Control Statement: Employ identity providers and authorization servers to manage user, device, and non-person entity (NPE) identities, attributes, and access rights supporting authentication and authorization decisions in accordance with [organization-defined parameter] using [organization-defined parameter]. Supplemental Guidance: Employ identity providers and authorization servers to manage user, device, and non-person entity (NPE) identities, attributes, and access rights supporting authentication and authorization decisions in accordance with [organization-defined parameter] using [organization-defined parameter]. Identity providers, both internal and external to the organization, manage the user, device, and NPE authenticators and issue statements, often called identity assertions, attesting to identities of other systems or systems components. Authorization servers create and issue access tokens to identified and authenticated users and devices that can be used to gain access to system or information resources. For example, single sign-on (SSO) provides identity provider and authorization server functions. Authenticator management (to include credential management) is covered by IA-05.

Under the FedRAMP Moderate baseline, IA-5.2 (IA-5.2 Public Key-based Authentication): FedRAMP Moderate Baseline · IA-5.2 · Public Key-based Authentication Control Statement: (a) For public key-based authentication: (1) Enforce authorized access to the corresponding private key; and (2) Map the authenticated identity to the account of the individual or group; and (b) When public key infrastructure (PKI) is used: (1) Validate certificates by constructing and verifying a certification path to an accepted trust anchor, including checking certificate status information; and (

Under the FedRAMP Moderate baseline, IA-4 (IA-4 Identifier Management): FedRAMP Moderate Baseline · IA-4 · Identifier Management Control Statement: Manage system identifiers by: a. Receiving authorization from [organization-defined parameter] to assign an individual, group, role, service, or device identifier; b. Selecting an identifier that identifies an individual, group, role, service, or device; c. Assigning the identifier to the intended individual, group, role, service, or device; and d. Preventing reuse of identifiers for [organization-defined parameter]. S

Control IA-8: the PIV credentials as defined in cited references. PIV-I credentials are the credentials issued by a PIV-I provider whose PIV-I certificate policy maps to the Federal Bridge PIV-I Certificate Policy. A PIV-I provider is cross-certified with the FBCA (directly or through another PKI bridge) with policies that have been mapped and approved as meeting the requirements of the PIV-I policies defined in the FBCA certificate policy. T h s i p u b l i c a t i o n i s Related Controls: None. a v a i l l a b e f r e e o f c h a r g e f r o m : <https://doi.org/10.6028/NIST.SP.800-53r5>. (6) IDENTIFICATION AND AUTHENTICATION (NON-ORGANIZATIONAL USERS) | DISASSOCIABILITY Implement the following measures to disassociate user attributes or identifier assertion relationships among individuals, credential service providers, and relying parties: [Assignment: organization-defined measures]. Discussion: Federated identity solutions can create increased privacy risks due to the tracking and profiling of individuals. Using identifier mapping tables or cryptographic techniques to blind credential service providers and

relying parties from each other or to make identity attributes less visible to transmitting parties can reduce these privacy risks. Related Controls: None. References: [OMB A-130], [FED PKI], [FIPS 201-2], [SP 800-63-3], [SP 800-79-2], [SP 800-116], [IR 8062].

Under the FedRAMP Moderate baseline, IA-2.5 (IA-2.5 Individual Authentication with Group Authentication): FedRAMP Moderate Baseline · IA-2.5 · Individual Authentication with Group Authentication Control Statement: When shared accounts or authenticators are employed, require users to be individually authenticated before granting access to the shared accounts or resources. Supplemental Guidance: When shared accounts or authenticators are employed, require users to be individually authenticated before granting access to the shared accounts or resources. Individual authentication prior to shared group

NIST SP 800-53 Rev 5 control IA-5 (Authenticator Management) is assessed by examining, interviewing, and testing: IA-5 · Authenticator Management Control Statement: Manage system authenticators by: a. Verifying, as part of the initial authenticator distribution, the identity of the individual, group, role, service, or device receiving the authenticator; b. Establishing initial authenticator content for any authenticators issued by the organization; c. Ensuring that authenticators have sufficient strength of mechanism for their intended use; d. Establishing and implementing administrative procedures for ini

NIST SP 800-53 Rev 5 control IA-8.4 (Use of Defined Profiles) is defined as follows: IA-8.4 · Use of Defined Profiles Control Statement: Conform to the following profiles for identity management [organization-defined parameter]. Supplemental Guidance: Conform to the following profiles for identity management [organization-defined parameter]. Organizations define profiles for identity management based on open identity management standards. To ensure that open identity management standards are viable, robust, reliable, sustainable, and interoperable as documented, the Federal Government assesses and scopes the standards and technology implementations against applicable laws, e

NIST SP 800-53 Rev 5 control IA-12.3 (Identity Evidence Validation and Verification) is assessed by examining, interviewing, and testing: IA-12.3 · Identity Evidence Validation and Verification Control Statement: Require that the presented identity evidence be validated and verified through [organization-defined parameter]. Supplemental Guidance: Require that the presented identity evidence be validated and verified through [organization-defined parameter]. Validation and verification of identity evidence increases the assurance that accounts and identifiers are being established for the correct user and authenticators are being

NIST SP 800-53 Rev 5 control IA-2.6 (Access to Accounts ·separate Device) is assessed by examining, interviewing, and testing: IA-2.6 · Access to Accounts ·separate Device Control Statement: Implement multi-factor authentication for [organization-defined parameter] access to [organization-defined parameter] such that: (a) One of the factors is provided by a device separate from the system gaining access; and (b) The device meets [organization-defined parameter]. Supplemental Guidance: Implement multi-factor authentication for [organization-defined parameter] access to [organization-defined parameter] such that: (a) On

IA-12 · Identity Proofing Control Statement: a. Identity proof users that require accounts for logical access to systems based on appropriate identity assurance level requirements as specified in applicable standards and guidelines; b. Resolve user identities to a unique individual; and c. Collect, validate, and verify identity evidence. Supplemental Guidance: a. Identity proof users that require accounts for logical access to systems based on appropriate identity assurance level requirements as specified in applicable standards and guidelines; b. Resolve user identities to a unique individual; and c. Collect, validate, and verify identity evidence. Identity proofing is the process of collecting, validating, and verifying a user's identity information for the purposes of establishing credentials for accessing a system. Identity proofing is intended to mitigate threats to the registration of users and the establishment of their accounts. Standards and guidelines specifying identity assurance levels for identity proofing include [SP 800-63-3](#737513fa-6758-403f-831d-5ddab5e23cb3) and [SP 800-63A](#9099ed2c-922a-493d-bcb4-d896192243ff) . Organizations may be subject to laws, executive orders, directives, regulations, or policies that address the collection of identity evidence. Organizational personnel consult with the senior agency official for privacy and legal counsel

regarding such requirements.

NIST SP 800-53 Rev 5 control IA-4.8 (Pairwise Pseudonymous Identifiers) summarizes the requirements for this control: IA-4.8 · Pairwise Pseudonymous Identifiers Control Statement: Generate pairwise pseudonymous identifiers. Supplemental Guidance: Generate pairwise pseudonymous identifiers. A pairwise pseudonymous identifier is an opaque unguessable subscriber identifier generated by an identity provider for use at a specific individual relying party. Generating distinct pairwise pseudonymous identifiers with no identifying information about a subscriber discourages subscriber activity tracking and profiling b

NIST SP 800-171 Rev 3 control 03.05.04 (03.05.04 Replay-Resistant Authentication) requires organizations to implement the following: 03.05.04 · Replay-Resistant Authentication Supplemental Guidance: Authentication processes resist replay attacks if it is impractical to successfully authenticate by recording or replaying previous authentication messages. Replay-resistant techniques include protocols that use nonces or challenges, such as time synchronous or challenge-response one-time authenticators. Assessment Objectives: - replay-resistant authentication mechanisms for access to privileged accounts are implemented. - repla For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.05.04.

NIST SP 800-171 Rev 3 control 03.05.04 (03.05.04 Replay-Resistant Authentication) falls under the Identification and Authentication family. 03.05.04 · Replay-Resistant Authentication Supplemental Guidance: Authentication processes resist replay attacks if it is impractical to successfully authenticate by recording or replaying previous authentication messages. Replay-resistant techniques include protocols that use nonces or challenges, such as time synchronous or challenge-response one-time authenticators. Assessment Objectives: - replay-resistant authentication mechanisms for access to privileged accounts are implemented. - repla Supplemental Guidance: Authentication processes resist replay attacks if it is impractical to successfully authenticate by recording or replaying previous authentication messages. Replay-resistant techniques include protocols that use nonces or challenges, such as time synchronous or challenge-response one-time authenticators.

IA-5.15 · GSA-approved Products and Services Control Statement: Use only General Services Administration-approved products and services for identity, credential, and access management. Supplemental Guidance: Use only General Services Administration-approved products and services for identity, credential, and access management. General Services Administration (GSA)-approved products and services are products and services that have been approved through the GSA conformance program, where applicable, and posted to the GSA Approved Products List. GSA provides guidance for teams to design and build functional and secure systems that comply with Federal Identity, Credential, and Access Management (FICAM) policies, technologies, and implementation patterns.

NIST SP 800-53 Rev 5 control IA-3.4 (Device Attestation) summarizes the requirements for this control: IA-3.4 · Device Attestation Control Statement: Handle device identification and authentication based on attestation by [organization-defined parameter]. Supplemental Guidance: Handle device identification and authentication based on attestation by [organization-defined parameter]. Device attestation refers to the identification and authentication of a device based on its configuration and known operating state. Device attestation can be determined via a cryptographic hash of the device. If dev

NIST SP 800-53 Rev 5 control IA-13.2 (Verification of Identity Assertions and Access Tokens) is defined as follows: IA-13.2 · Verification of Identity Assertions and Access Tokens Control Statement: The source and integrity of identity assertions and access tokens are verified before granting access to system and information resources. Supplemental Guidance: The source and integrity of identity assertions and access tokens are verified before granting access to system and information resources. This includes verification of digital signatures protecting identity assertions and access tokens, as well as included metadata. Metadata includes information about the access request such as information unique to

NIST SP 800-171 Rev 3 control 03.05.04 (03.05.04 Replay-Resistant Authentication) is assessed by examining the following: Assessment Objectives: - replay-resistant authentication mechanisms for access to privileged accounts are implemented. - replay-resistant authentication mechanisms for

access to non-privileged accounts are implemented.

NIST SP 800-53 Rev 5 control IA-5.10 (Dynamic Credential Binding) is assessed by examining, interviewing, and testing: IA-5.10 · Dynamic Credential Binding Control Statement: Bind identities and authenticators dynamically using the following rules: [organization-defined parameter]. Supplemental Guidance: Bind identities and authenticators dynamically using the following rules: [organization-defined parameter]. Authentication requires some form of binding between an identity and the authenticator that is used to confirm the identity. In conventional approaches, binding is established by pre-provisioning both th

Under the FedRAMP High baseline, IA-2.8 (IA-2.8 Access to Accounts · Replay Resistant): FedRAMP High Baseline · IA-2.8 · Access to Accounts · Replay Resistant Control Statement: Implement replay-resistant authentication mechanisms for access to [organization-defined parameter]. Supplemental Guidance: Implement replay-resistant authentication mechanisms for access to [organization-defined parameter]. Authentication processes resist replay attacks if it is impractical to achieve successful authentications by replaying previous authentication messages. Replay-resistant techniques in

NIST SP 800-171 Rev 3 control 03.05.04 (03.05.04 Replay-Resistant Authentication) requires organizations to implement the following: 03.05.04 · Replay-Resistant Authentication Supplemental Guidance: Authentication processes resist replay attacks if it is impractical to successfully authenticate by recording or replaying previous authentication messages. Replay-resistant techniques include protocols that use nonces or challenges, such as time synchronous or challenge-response one-time authenticators. Assessment Objectives: - replay-resistant authentication mechanisms for access to privileged accounts are implemented. - repla For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.05.04.

NIST SP 800-53 Rev 5 control IA-13.3 (Token Management) summarizes the requirements for this control: IA-13.3 · Token Management Control Statement: In accordance with [organization-defined parameter], assertions and access tokens are: (a) generated; (b) issued; (c) refreshed; (d) revoked; (e) time-restricted; and (f) audience-restricted. Supplemental Guidance: In accordance with [organization-defined parameter], assertions and access tokens are: (a) generated; (b) issued; (c) refreshed; (d) revoked; (e) time-restricted; and (f) audience-restricted. An access token is a piece of data that repre

NIST SP 800-53 Rev 5 control IA-5 (Authenticator Management) is defined as follows: IA-5 · Authenticator Management Control Statement: Manage system authenticators by: a. Verifying, as part of the initial authenticator distribution, the identity of the individual, group, role, service, or device receiving the authenticator; b. Establishing initial authenticator content for any authenticators issued by the organization; c. Ensuring that authenticators have sufficient strength of mechanism for their intended use; d. Establishing and implementing administrative procedures for initial authenticator distribution, for lost or compromised or damaged authenticators, and for revoking

NIST SP 800-171 Rev 3 control 03.05.05 (03.05.05 Identifier Management) is assessed by examining the following: Assessment Objectives: - authorization is received from organizational personnel or roles to assign an individual, group, role, service, or device identifier. - an identifier that identifies an individual, group, role, service, or device is selected. - an identifier that identifies an individual, group, role, service, or device is assigned. - the reuse of identifiers for [organization-defined parameter] is prevented. - individual identifiers are managed by uniquely identifying each individual as [organization-defined parameter].

Under the FedRAMP Low baseline, IA-5.1 (IA-5.1 Password-based Authentication): FedRAMP Low Baseline · IA-5.1 · Password-based Authentication Control Statement: For password-based authentication: (a) Maintain a list of commonly-used, expected, or compromised passwords and update the list [organization-defined parameter] and when organizational passwords are suspected to have been compromised directly or indirectly; (b) Verify, when users create or update passwords, that the passwords are not found on the list of commonly-used, expected, or compromised passwords in IA-5(1)(

NIST SP 800-53 Rev 5 control IA-4.1 (Prohibit Account Identifiers as Public Identifiers) summarizes the requirements for this control: IA-4.1 · Prohibit Account Identifiers as Public Identifiers Control Statement: Prohibit the use of system account identifiers that are the same as public identifiers for individual accounts. Supplemental Guidance: Prohibit the use of system account identifiers that are the same as public identifiers for individual accounts. Prohibiting account identifiers as public identifiers applies to any publicly disclosed account identifier used for communication such as, electronic mail and instant messa

NIST SP 800-53 Rev 5 control IA-4.5 (Dynamic Management) is assessed by examining, interviewing, and testing: IA-4.5 · Dynamic Management Control Statement: Manage individual identifiers dynamically in accordance with [organization-defined parameter]. Supplemental Guidance: Manage individual identifiers dynamically in accordance with [organization-defined parameter]. In contrast to conventional approaches to identification that presume static accounts for preregistered users, many distributed systems establish identifiers at runtime for entities that were previously unknown. When identifiers are estab

03.05.04 · Replay-Resistant Authentication Supplemental Guidance: Authentication processes resist replay attacks if it is impractical to successfully authenticate by recording or replaying previous authentication messages. Replay-resistant techniques include protocols that use nonces or challenges, such as time synchronous or challenge-response one-time authenticators. Assessment Objectives: - replay-resistant authentication mechanisms for access to privileged accounts are implemented. - replay-resistant authentication mechanisms for access to non-privileged accounts are implemented.

NIST SP 800-171 Rev 3 control 03.05.12 (03.05.12 Authenticator Management) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Identification and Authentication (IA) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

Under the FedRAMP Moderate baseline, IA-5.7 (IA-5.7 No Embedded Unencrypted Static Authenticators): FedRAMP Moderate Baseline · IA-5.7 · No Embedded Unencrypted Static Authenticators Control Statement: Ensure that unencrypted static authenticators are not embedded in applications or other forms of static storage. Supplemental Guidance: Ensure that unencrypted static authenticators are not embedded in applications or other forms of static storage. In addition to applications, other forms of static storage include access scripts and function keys. Organizations exercise caution when determinin

NIST SP 800-53 Rev 5 control IA-2.2 (Multi-factor Authentication to Non-privileged Accounts) is assessed by examining, interviewing, and testing: IA-2.2 · Multi-factor Authentication to Non-privileged Accounts Control Statement: Implement multi-factor authentication for access to non-privileged accounts. Supplemental Guidance: Implement multi-factor authentication for access to non-privileged accounts. Multi-factor authentication requires the use of two or more different factors to achieve authentication. The authentication factors are defined as follows: something you know (e.g., a personal identification number [PIN]), something you h

NIST SP 800-53 Rev 5 control IA-5.10 (Dynamic Credential Binding) summarizes the requirements for this control: IA-5.10 · Dynamic Credential Binding Control Statement: Bind identities and authenticators dynamically using the following rules: [organization-defined parameter]. Supplemental Guidance: Bind identities and authenticators dynamically using the following rules: [organization-defined parameter]. Authentication requires some form of binding between an identity and the authenticator that is used to confirm the identity. In conventional approaches, binding is established by pre-provisioning both th

Implementing 03.05.07 (03.05.07 Password Management) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.05.07 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-

level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.05.07 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

FedRAMP Low Baseline · IA-8.1 · Acceptance of PIV Credentials from Other Agencies Control Statement: Accept and electronically verify Personal Identity Verification-compliant credentials from other federal agencies. Supplemental Guidance: Accept and electronically verify Personal Identity Verification-compliant credentials from other federal agencies. Acceptance of Personal Identity Verification (PIV) credentials from other federal agencies applies to both logical and physical access control systems. PIV credentials are those credentials issued by federal agencies that conform to FIPS Publication 201 and supporting guidelines. The adequacy and reliability of PIV card issuers are addressed and authorized using [SP 800-79-2](#10963761-58fc-4b20-b3d6-b44a54daba03). Assessment Objectives: Accept and electronically verify Personal Identity Verification-compliant credentials from other federal agencies.

NIST SP 800-171 Rev 3 control 03.05.01 (03.05.01 User Identification and Authentication) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Identification and Authentication (IA) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

Under the FedRAMP High baseline, IA-1 (IA-1 Policy and Procedures): FedRAMP High Baseline · IA-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] identification and authentication policy that: 2. Procedures to facilitate the implementation of the identification and authentication policy and the associated identification and authentication controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination

Under the FedRAMP Low baseline, IA-8.2 (IA-8.2 Acceptance of External Authenticators): FedRAMP Low Baseline · IA-8.2 · Acceptance of External Authenticators Control Statement: (a) Accept only external authenticators that are NIST-compliant; and (b) Document and maintain a list of accepted external authenticators. Supplemental Guidance: (a) Accept only external authenticators that are NIST-compliant; and (b) Document and maintain a list of accepted external authenticators. Acceptance of only NIST-compliant external authenticators applies to organizational systems that are accessible

NIST SP 800-53 Rev 5 control IA-12.1 (Supervisor Authorization) summarizes the requirements for this control: IA-12.1 · Supervisor Authorization Control Statement: Require that the registration process to receive an account for logical access includes supervisor or sponsor authorization. Supplemental Guidance: Require that the registration process to receive an account for logical access includes supervisor or sponsor authorization. Including supervisor or sponsor authorization as part of the registration process provides an additional level of scrutiny to ensure that the user's management chain is aware

NIST SP 800-171 Rev 3 control 03.05.02 (03.05.02 Device Identification and Authentication) is assessed by examining the following: Assessment Objectives: - [organization-defined parameter] are authenticated before establishing a system connection. - [organization-defined parameter] are uniquely identified before establishing a system connection.

NIST SP 800-53 Rev 5 control IA-13 (Identity Providers and Authorization Servers) summarizes the requirements for this control: IA-13 · Identity Providers and Authorization Servers Control Statement: Employ identity providers and authorization servers to manage user, device, and non-person entity (NPE) identities, attributes, and access rights supporting authentication and authorization decisions in accordance with [organization-defined parameter] using [organization-defined parameter]. Supplemental Guidance: Employ identity providers and authorization servers to manage user, device, and non-person entity (NPE) identities

NIST SP 800-171 Rev 3 control 03.05.01 (03.05.01 User Identification and Authentication) requires

organizations to implement the following: Control Statement: SR-03.05.01.a Uniquely identify and authenticate system users, and associate that unique identification with processes acting on behalf of those users. SR-03.05.01.b Re-authenticate users when [organization-defined parameter] . For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.05.01.

NIST SP 800-53 Rev 5 control IA-8.4 (Use of Defined Profiles) is assessed by examining, interviewing, and testing: IA-8.4 · Use of Defined Profiles Control Statement: Conform to the following profiles for identity management [organization-defined parameter]. Supplemental Guidance: Conform to the following profiles for identity management [organization-defined parameter]. Organizations define profiles for identity management based on open identity management standards. To ensure that open identity management standards are viable, robust, reliable, sustainable, and interoperable as documented, the Federal Go

NIST SP 800-171 Rev 3 control 03.05.01 (03.05.01 User Identification and Authentication) is assessed by examining the following: Assessment Objectives: - system users are uniquely identified. - system users are authenticated. - processes acting on behalf of users are associated with uniquely identified and authenticated system users. - users are reauthenticated when [organization-defined parameter] .

NIST SP 800-171 Rev 3 control 03.05.11 (03.05.11 Authentication Feedback) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Identification and Authentication (IA) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control IA-4.6 (Cross-organization Management) summarizes the requirements for this control: IA-4.6 · Cross-organization Management Control Statement: Coordinate with the following external organizations for cross-organization management of identifiers: [organization-defined parameter]. Supplemental Guidance: Coordinate with the following external organizations for cross-organization management of identifiers: [organization-defined parameter]. Cross-organization identifier management provides the capability to identify individuals, groups, roles, or devices when conducting cross-organ

NIST SP 800-53 Rev 5 control IA-3.3 (Dynamic Address Allocation) is assessed by examining, interviewing, and testing: IA-3.3 · Dynamic Address Allocation Control Statement: (a) Where addresses are allocated dynamically, standardize dynamic address allocation lease information and the lease duration assigned to devices in accordance with [organization-defined parameter] ; and (b) Audit lease information when assigned to a device. Supplemental Guidance: (a) Where addresses are allocated dynamically, standardize dynamic address allocation lease information and the lease duration assigned to devices in accordance

Control IA-12: . Control Enhancements: (1) IDENTITY PROOFING | SUPERVISOR AUTHORIZATION Require that the registration process to receive an account for logical access includes supervisor or sponsor authorization. Discussion: Including supervisor or sponsor authorization as part of the registration process provides an additional level of scrutiny to ensure that the user's management chain is aware of the account, the account is essential to carry out organizational missions and functions, and the user's privileges are appropriate for the anticipated responsibilities and authorities within the organization. Related Controls: None. (2) IDENTITY PROOFING | IDENTITY EVIDENCE Require evidence of individual identification be presented to the registration authority. Discussion: Identity evidence, such as documentary evidence or a combination of documents and biometrics, reduces the likelihood of individuals using fraudulent identification to establish an identity or at least increases the work factor of potential adversaries. The forms of acceptable evidence are consistent with the risks to the systems, roles, and privileges associated with the user's account. Related Controls: None. (3) IDENTITY PROOFING | IDENTITY EVIDENCE VALIDATION AND VERIFICATION Require that the presented identity evidence be validated and verified through [Assignment: organizational defined methods of validation and verification]. Discussion: Validation and verification of identity evidence increases the assurance that accounts and identifiers are being established for the correct user and authenticators are being bound to that user. Validation refers to the process of confirming that the

evidence is genuine and authentic, and the data contained in the evidence is correct, current, and related to an individual. Verification confirms and establishes a linkage between the claimed identity and the actual existence of the user presenting the evidence.

NIST SP 800-53 Rev 5 control IA-2.10 (Single Sign-on) summarizes the requirements for this control: IA-2.10 · Single Sign-on Control Statement: Provide a single sign-on capability for [organization-defined parameter]. Supplemental Guidance: Provide a single sign-on capability for [organization-defined parameter]. Single sign-on enables users to log in once and gain access to multiple system resources. Organizations consider the operational efficiencies provided by single sign-on capabilities with the risk introduced by allowing access to multiple systems via a single authentication event. Si

IA-4.8 · Pairwise Pseudonymous Identifiers Control Statement: Generate pairwise pseudonymous identifiers. Supplemental Guidance: Generate pairwise pseudonymous identifiers. A pairwise pseudonymous identifier is an opaque unguessable subscriber identifier generated by an identity provider for use at a specific individual relying party. Generating distinct pairwise pseudonymous identifiers with no identifying information about a subscriber discourages subscriber activity tracking and profiling beyond the operational requirements established by an organization. The pairwise pseudonymous identifiers are unique to each relying party except in situations where relying parties can show a demonstrable relationship justifying an operational need for correlation, or all parties consent to being correlated in such a manner.

NIST SP 800-53 Rev 5 control IA-5.7 (No Embedded Unencrypted Static Authenticators) summarizes the requirements for this control: IA-5.7 · No Embedded Unencrypted Static Authenticators Control Statement: Ensure that unencrypted static authenticators are not embedded in applications or other forms of static storage. Supplemental Guidance: Ensure that unencrypted static authenticators are not embedded in applications or other forms of static storage. In addition to applications, other forms of static storage include access scripts and function keys. Organizations exercise caution when determining whether embedded or stored

Under the FedRAMP Moderate baseline, IA-6 (IA-6 Authentication Feedback): FedRAMP Moderate Baseline · IA-6 · Authentication Feedback Control Statement: Obscure feedback of authentication information during the authentication process to protect the information from possible exploitation and use by unauthorized individuals. Supplemental Guidance: Obscure feedback of authentication information during the authentication process to protect the information from possible exploitation and use by unauthorized individuals. Authentication feedback from systems does not provide

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Identification and Authentication 3.5.1 User Identification and Authentication a. Uniquely identify and authenticate system users, and associate that unique identification with processes acting on behalf of those users. b. Re-authenticate users when [Assignment: organization-defined circumstances or situations requiring re-authentication] (03.05.01.b). Related Controls: IA-02, IA-11 ODP Values ODP Identifier ODP Assignment Text ODP Value 03.05.01.b [Assignment: organization-defined circumstances or situations requiring re-authentication] roles, authenticators, or credentials change (including modification of user privilege); when security categories of systems change; when the execution of privileged functions occurs; and after a session termination Identification and A

NIST SP 800-53 Rev 5 control IA-2.10 (Single Sign-on): IA-2.10 · Single Sign-on Control Statement: Provide a single sign-on capability for [organization-defined parameter]. Supplemental Guidance: Provide a single sign-on capability for [organization-defined parameter]. Single sign-on enables users to log in once and gain access to multiple system resources. Organizations consider the operational efficiencies provided by single sign-on capabilities w

NIST SP 800-171 Rev 3 control 03.05.03 (03.05.03 Multi-Factor Authentication) falls under the Identification and Authentication family. 03.05.03 · Multi-Factor Authentication Supplemental Guidance: This requirement applies to user accounts. Multi-factor authentication requires the use of two or more different factors to achieve authentication. The authentication factors are defined as follows: something you know (e.g., a personal identification number .PIN), something you have (e.g., a physical authenticator, such as a cryptographic private key), or something you are (e.g., a biometric). Multi-factor authentication solutions th Supplemental Guidance: This requirement

applies to user accounts. Multi-factor authentication requires the use of two or more different factors to achieve authentication. The authentication factors are defined as follows: something you know (e.g., a personal identification number .PIN), something you have (e.g., a physical authenticator, such as a cryptographic private key), or something you are (e.g., a biometric). Multi-factor authentication solutions that feature physical authenticators inclu

NIST SP 800-53 Rev 5 control IA-12.6 (Accept Externally-validated Identities) is assessed by examining, interviewing, and testing: IA-12.6 · Accept Externally-validated Identities Control Statement: Accept externally-validated identities at [organization-defined parameter]. Supplemental Guidance: Accept externally-validated identities at [organization-defined parameter]. To limit unnecessary re-validation of identities, particularly of non-PIV users, organizations accept proofing conducted at a commensurate level of assurance by other agencies or organizations. Proofing is consistent with organizational security policy and the id

NIST SP 800-53 Rev 5 control IA-12.5 (Address Confirmation) summarizes the requirements for this control: IA-12.5 · Address Confirmation Control Statement: Require that a [organization-defined parameter] be delivered through an out-of-band channel to verify the users address (physical or digital) of record. Supplemental Guidance: Require that a [organization-defined parameter] be delivered through an out-of-band channel to verify the users address (physical or digital) of record. To make it more difficult for adversaries to pose as legitimate users during the identity proofing process, organizatio

NIST SP 800-171 Rev 3 control 03.05.12 (03.05.12 Authenticator Management) is assessed by examining the following: Assessment Objectives: - the identity of the individual, group, role, service, or device receiving the authenticator as part of the initial authenticator distribution is verified. - initial authenticator content for any authenticators issued by the organization is established. - administrative procedures for initial authenticator distribution are established. - administrative procedures for lost, compromised, or damaged authenticators are established. - administrative procedures for revoking authenticators are established. - administrative procedures for initial authenticator distribution are

NIST SP 800-171 Rev 3 control 03.05.03 (03.05.03 Multi-Factor Authentication) requires organizations to implement the following: 03.05.03 · Multi-Factor Authentication Supplemental Guidance: This requirement applies to user accounts. Multi-factor authentication requires the use of two or more different factors to achieve authentication. The authentication factors are defined as follows: something you know (e.g., a personal identification number .PIN), something you have (e.g., a physical authenticator, such as a cryptographic private key), or something you are (e.g., a biometric). Multi-factor authentication solutions th For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.05.03.

NIST SP 800-53 Rev 5 control IA-5.13 (Expiration of Cached Authenticators) is assessed by examining, interviewing, and testing: IA-5.13 · Expiration of Cached Authenticators Control Statement: Prohibit the use of cached authenticators after [organization-defined parameter]. Supplemental Guidance: Prohibit the use of cached authenticators after [organization-defined parameter]. Cached authenticators are used to authenticate to the local machine when the network is not available. If cached authentication information is out of date, the validity of the authentication information may be questionable.

Under the FedRAMP High baseline, IA-2.2 (IA-2.2 Multi-factor Authentication to Non-privileged Accounts): FedRAMP High Baseline · IA-2.2 · Multi-factor Authentication to Non-privileged Accounts Control Statement: Implement multi-factor authentication for access to non-privileged accounts. Supplemental Guidance: Implement multi-factor authentication for access to non-privileged accounts. Multi-factor authentication requires the use of two or more different factors to achieve authentication. The authentication factors are defined as follows: something you know (e.g., a personal identification number

NIST SP 800-171 Rev 3 control 03.05.04 (03.05.04 Replay-Resistant Authentication) is assessed by examining the following: Assessment Objectives: - replay-resistant authentication mechanisms for access to privileged accounts are implemented. - replay-resistant authentication mechanisms for

access to non-privileged accounts are implemented.

NIST SP 800-53 Rev 5 control IA-5.5 (Change Authenticators Prior to Delivery) summarizes the requirements for this control: IA-5.5 · Change Authenticators Prior to Delivery Control Statement: Require developers and installers of system components to provide unique authenticators or change default authenticators prior to delivery and installation. Supplemental Guidance: Require developers and installers of system components to provide unique authenticators or change default authenticators prior to delivery and installation. Changing authenticators prior to the delivery and installation of system components extends t

Under the FedRAMP Low baseline, IA-2 (IA-2 Identification and Authentication (Organizational Users)): FedRAMP Low Baseline · IA-2 · Identification and Authentication (Organizational Users) Control Statement: Uniquely identify and authenticate organizational users and associate that unique identification with processes acting on behalf of those users. Supplemental Guidance: Uniquely identify and authenticate organizational users and associate that unique identification with processes acting on behalf of those users. Organizations can satisfy the identification and authentication requirements by

NIST SP 800-53 Rev 5 control IA-7 (Cryptographic Module Authentication) summarizes the requirements for this control: IA-7 · Cryptographic Module Authentication Control Statement: Implement mechanisms for authentication to a cryptographic module that meet the requirements of applicable laws, executive orders, directives, policies, regulations, standards, and guidelines for such authentication. Supplemental Guidance: Implement mechanisms for authentication to a cryptographic module that meet the requirements of applicable laws, executive orders, directives, policies, regulations, standards, and guidelines for

From the DoD SP 800-171 Rev 3 Organization-Defined Parameters: Identification and Authentication 3.5.7 Password Management a. Maintain a list of commonly used, expected, or compromised passwords, and update the list [Assignment: organization-defined frequency] (03.05.07.a) and when organizational passwords are suspected to have been compromised. b. Verify that passwords are not found on the list of commonly used, expected, or compromised passwords when users create or update passwords. c. Transmit passwords only over cryptographically protected channels. d. Store passwords in a cryptographically protected form. e. Select a new password upon first use after account recovery. f. Enforce the following composition and complexity rules for passwords: [Assignment: organization-defined composition and complexity rules] (03.05.07.f). Related Contr

FedRAMP Moderate Baseline · IA-12.2 · Identity Evidence Control Statement: Require evidence of individual identification be presented to the registration authority. Supplemental Guidance: Require evidence of individual identification be presented to the registration authority. Identity evidence, such as documentary evidence or a combination of documents and biometrics, reduces the likelihood of individuals using fraudulent identification to establish an identity or at least increases the work factor of potential adversaries. The forms of acceptable evidence are consistent with the risks to the systems, roles, and privileges associated with the user-s account. Assessment Objectives: Require evidence of individual identification be presented to the registration authority.

NIST SP 800-171 Rev 3 control 03.05.05 (03.05.05 Identifier Management) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Identification and Authentication (IA) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-171 Rev 3 control 03.05.02 (03.05.02 Device Identification and Authentication) is assessed by examining the following: Assessment Objectives: - [organization-defined parameter] are authenticated before establishing a system connection. - [organization-defined parameter] are uniquely identified before establishing a system connection.

NIST SP 800-53 Rev 5 control IA-4.5 (Dynamic Management) summarizes the requirements for this control: IA-4.5 · Dynamic Management Control Statement: Manage individual identifiers dynamically in accordance with [organization-defined parameter]. Supplemental Guidance: Manage individual

identifiers dynamically in accordance with [organization-defined parameter]. In contrast to conventional approaches to identification that presume static accounts for preregistered users, many distributed systems establish identifiers at runtime for entities that were previously unknown. When identifiers are estab

NIST SP 800-171 Rev 3 control 03.05.02 (03.05.02 Device Identification and Authentication) falls under the Identification and Authentication family. 03.05.02 · Device Identification and Authentication Supplemental Guidance: Devices that require unique device-to-device identification and authentication are defined by type, device, or a combination of type and device. Organization-defined device types include devices that are not owned by the organization. Systems use shared known information (e.g., Media Access Control .MAC, Transmission Control Protocol/Internet Protocol .TCP/IP addresses) for device identification or organizational authentic Supplemental Guidance: Devices that require unique device-to-device identification and authentication are defined by type, device, or a combination of type and device. Organization-defined device types include devices that are not owned by the organization. Systems use shared known information (e.g., Media Access Control .MAC, Transmission Control Protocol/Internet Protocol .TCP/IP addresses) for device identification or organizational authentication solutions (e.g., Institute of Electrical and

NIST SP 800-53 Rev 5 control IA-2.5 (Individual Authentication with Group Authentication) is assessed by examining, interviewing, and testing: IA-2.5 · Individual Authentication with Group Authentication Control Statement: When shared accounts or authenticators are employed, require users to be individually authenticated before granting access to the shared accounts or resources. Supplemental Guidance: When shared accounts or authenticators are employed, require users to be individually authenticated before granting access to the shared accounts or resources. Individual authentication prior to shared group authentication mitigates th

| IA-2, Identification and Authentication (Organizational Users) | Uniquely identify and authenticate each privileged user. Also, see IA-2 control enhancements (1), (3), (6), (8), (11), and (12). | | IA-4, Identifier Management | Manage information system identifiers for all privileged users. | | IA-5, Authenticator Management | Manage information system authenticators for all privileged users. IA-5 control enhancements of particular interest include (1), (2), and (11). | | IA-8, Identification and Authentication (Non-Organizational Users) | Uniquely identify and authenticate each privileged user. Also, see IA-8 control enhancements (1) and (5). | | SC-8, Transmission Confidentiality and Integrity | Protect the confidentiality and integrity of all communications related to privileged user authentication and privileged sessions. | | SC-10, Network Disconnect | Terminate network connections from privileged accounts after a defined period of inactivity. | | SI-2, Flaw Remediation | Apply patches and other updates to correct vulnerabilities in protocols, services, etc. used for privileged user authentication. | | SI-4, Information System Monitoring | Perform ongoing monitoring of all privileged account usage. SI-4 control enhancements of particular interest include (20). |

Under the FedRAMP High baseline, IA-5.1 (IA-5.1 Password-based Authentication): FedRAMP High Baseline · IA-5.1 · Password-based Authentication Control Statement: For password-based authentication: (a) Maintain a list of commonly-used, expected, or compromised passwords and update the list [organization-defined parameter] and when organizational passwords are suspected to have been compromised directly or indirectly; (b) Verify, when users create or update passwords, that the passwords are not found on the list of commonly-used, expected, or compromised passwords in IA-5(1)

Under the FedRAMP Moderate baseline, IA-5.1 (IA-5.1 Password-based Authentication): FedRAMP Moderate Baseline · IA-5.1 · Password-based Authentication Control Statement: For password-based authentication: (a) Maintain a list of commonly-used, expected, or compromised passwords and update the list [organization-defined parameter] and when organizational passwords are suspected to have been compromised directly or indirectly; (b) Verify, when users create or update passwords, that the passwords are not found on the list of commonly-used, expected, or compromised passwords in IA-

Under the FedRAMP High baseline, IA-12.2 (IA-12.2 Identity Evidence): FedRAMP High Baseline · IA-12.2 · Identity Evidence Control Statement: Require evidence of individual identification be presented to the registration authority. Supplemental Guidance: Require evidence of individual identification be presented to the registration authority. Identity evidence, such as documentary evidence or a combination of documents and biometrics, reduces the likelihood of individuals using

fraudulent identification to establish an identity or at least increases the work fact

From the NIST SP 800-172 Rev 3 Final Public Draft: PROTECTION STRATEGY PRA ADVERSARY EFFECTS Preclude (Preempt), Impede (Exert), Expose (Detect) REFERENCES Source Control: IA-03(04) NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 03.05.04E No Embedded Unencrypted Static Authenticators 1112 Ensure that unencrypted static authenticators are not embedded in applications or other forms of static storage. DISCUSSION In addition to applications, other forms of static storage include access scripts and function keys. Organizations exercise caution when determining whether embedded or stored authenticators are encrypted or unencrypted. If authenticators are used in the manner stored, then those representations are considered unencrypted authenticators. This requirement en

Under the FedRAMP Moderate baseline, IA-4.4 (IA-4.4 Identify User Status): FedRAMP Moderate Baseline · IA-4.4 · Identify User Status Control Statement: Manage individual identifiers by uniquely identifying each individual as [organization-defined parameter]. Supplemental Guidance: Manage individual identifiers by uniquely identifying each individual as [organization-defined parameter]. Characteristics that identify the status of individuals include contractors, foreign nationals, and non-organizational users. Identifying the status of individuals by these characteris

From the NIST SP 800-172 Rev 3 Final Public Draft: NIST SP 800-172r3 fpd (Final Public Draft) Enhanced Security Requirements for Protecting CUI September 2025 A potential risk of using password managers is that adversaries can target the 1084 collection of passwords generated by the password manager. Therefore, the passwords require strong protection, including encrypting the passwords. This requirement enhances SP 800-171 requirement 03.05.07. PROTECTION STRATEGY PRA ADVERSARY EFFECTS Preclude (Preempt), Impede (Delay, Exert) REFERENCES Source Control: IA-05(18) 03.0 5.03E Device Attestation Handle device identification and authentication based on attestation by [Assignment: organization-defined configuration management process]. DISCUSSION Device attestation refers to the identification and authentication of a device b

NIST SP 800-53 Rev 5 control IA-5.6 (Protection of Authenticators) is assessed by examining, interviewing, and testing: IA-5.6 · Protection of Authenticators Control Statement: Protect authenticators commensurate with the security category of the information to which use of the authenticator permits access. Supplemental Guidance: Protect authenticators commensurate with the security category of the information to which use of the authenticator permits access. For systems that contain multiple security categories of information without reliable physical or logical separation between categories, authenticators us

Under the FedRAMP High baseline, IA-2.12 (IA-2.12 Acceptance of PIV Credentials): FedRAMP High Baseline · IA-2.12 · Acceptance of PIV Credentials Control Statement: Accept and electronically verify Personal Identity Verification-compliant credentials. Supplemental Guidance: Accept and electronically verify Personal Identity Verification-compliant credentials. Acceptance of Personal Identity Verification (PIV)-compliant credentials applies to organizations implementing logical access control and physical access control systems. PIV-compliant credentials are those credentials

Under the FedRAMP Moderate baseline, IA-3 (IA-3 Device Identification and Authentication): FedRAMP Moderate Baseline · IA-3 · Device Identification and Authentication Control Statement: Uniquely identify and authenticate [organization-defined parameter] before establishing a [organization-defined parameter] connection. Supplemental Guidance: Uniquely identify and authenticate [organization-defined parameter] before establishing a [organization-defined parameter] connection. Devices that require unique device-to-device identification and authentication are defined by type, device, or

NIST SP 800-53 Rev 5 control IA-2.2 (Multi-factor Authentication to Non-privileged Accounts) summarizes the requirements for this control: IA-2.2 · Multi-factor Authentication to Non-privileged Accounts Control Statement: Implement multi-factor authentication for access to non-privileged accounts. Supplemental Guidance: Implement multi-factor authentication for access to non-privileged accounts. Multi-factor authentication requires the use of two or more different factors to achieve authentication. The authentication factors are defined as follows: something you know (e.g., a personal identification number [PIN]), something you h

NIST SP 800-171 Rev 3 control 03.05.01 (03.05.01 User Identification and Authentication) requires organizations to implement the following: Control Statement: SR-03.05.01.a Uniquely identify and authenticate system users, and associate that unique identification with processes acting on behalf of those users. SR-03.05.01.b Re-authenticate users when [organization-defined parameter] . For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.05.01.

Implementing 03.05.02 (03.05.02 Device Identification and Authentication) differs between cloud and on-premises environments in several ways: ****On-premises****: The organization has direct control over all infrastructure components. Implementation of 03.05.02 involves configuring local systems, network devices, and security tools. The organization is fully responsible for all aspects of the control. ****Cloud (IaaS/PaaS/SaaS)****: Responsibility is shared between the organization and the Cloud Service Provider (CSP). Under the FedRAMP shared responsibility model: - The CSP handles infrastructure-level controls (physical security, hypervisor, network backbone) - The organization handles application-level controls, user access, and data protection - The split depends on the service model (IaaS gives more control, SaaS gives less) For CMMC Level 2, the organization must document in their SSP which components of 03.05.02 are implemented by the CSP (with reference to the CSP's FedRAMP authorization) and which are implemented by the organization. The CUI boundary must be clearly defined regardless of environment.

NIST SP 800-53 Rev 5 control IA-5.9 (Federated Credential Management) is assessed by examining, interviewing, and testing: IA-5.9 · Federated Credential Management Control Statement: Use the following external organizations to federate credentials: [organization-defined parameter]. Supplemental Guidance: Use the following external organizations to federate credentials: [organization-defined parameter]. Federation provides organizations with the capability to authenticate individuals and devices when conducting cross-organization activities involving the processing, storage, or transmission of information. Using a

NIST SP 800-53 Rev 5 control IA-10 (Adaptive Authentication) is assessed by examining, interviewing, and testing: IA-10 · Adaptive Authentication Control Statement: Require individuals accessing the system to employ [organization-defined parameter] under specific [organization-defined parameter]. Supplemental Guidance: Require individuals accessing the system to employ [organization-defined parameter] under specific [organization-defined parameter]. Adversaries may compromise individual authentication mechanisms employed by organizations and subsequently attempt to impersonate legitimate users. To address

Control IA-5: s i p u b l i c a t i o n i s a v a i l a b e f r e e o f c h a r g e f r o m : h t
t p s : / / d o i . o r g / 1 0 . 6 0 2 8 / N S T S P . 8 0 0 - 5 3 r 5 I . NIST SP 800-53, REV. 5
SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

Discussion: When individuals have accounts on multiple systems and use the same authenticators such as passwords, there is the risk that a compromise of one account may lead to the compromise of other accounts. Alternative approaches include having different authenticators (passwords) on all systems, employing a single sign-on or federation mechanism, or using some form of one-time passwords on all systems. Organizations can also use rules of behavior (see PL-4) and access agreements (see PS-6) to mitigate the risk of multiple system accounts. Related Controls: PS-6. (9) AUTHENTICATOR MANAGEMENT | FEDERATED CREDENTIAL MANAGEMENT Use the following external organizations to federate credentials: [Assignment: organization-defined external organizations]. Discussion: Federation provides organizations with the capability to authenticate individuals and devices when conducting cross-organization activities involving the processing, storage, or transmission of information. Using a specific list of approved external organizations for authentication helps to ensure that those organizations are vetted and trusted. Related Controls: AU-7, AU-16. (10) AUTHENTICATOR MANAGEMENT | DYNAMIC CREDENTIAL BINDING Bind identities and authenticators dynamically using the following rules: [Assignment: organization-defined binding rules]. Discussion: Authentication requires some form of binding between an identity and the authenticator that is used to confirm the identity.

FedRAMP High Baseline · IA-5.13 · Expiration of Cached Authenticators Control Statement: Prohibit the use of cached authenticators after [organization-defined parameter]. Supplemental Guidance: Prohibit the use of cached authenticators after [organization-defined parameter]. Cached

authenticators are used to authenticate to the local machine when the network is not available. If cached authentication information is out of date, the validity of the authentication information may be questionable. Assessment Objectives: Prohibit the use of cached authenticators after [organization-defined parameter]. FedRAMP Parameter Values: ia-05.13_odp: the time period after which the use of cached authenticators is prohibited is defined;

NIST SP 800-171 Rev 3 control 03.05.03 (03.05.03 Multi-Factor Authentication) is assessed by examining the following: Assessment Objectives: - multi-factor authentication for access to privileged accounts is implemented. - multi-factor authentication for access to non-privileged accounts is implemented.

network] connection using bidirectional authentication that is cryptographically based. Discussion: A local connection is a connection with a device that communicates without the use of a network. A network connection is a connection with a device that communicates through a network.

NIST SP 800-171 Rev 3 control 03.05.02 (03.05.02 Device Identification and Authentication) requires organizations to implement the following: 03.05.02 · Device Identification and Authentication Supplemental Guidance: Devices that require unique device-to-device identification and authentication are defined by type, device, or a combination of type and device. Organization-defined device types include devices that are not owned by the organization. Systems use shared known information (e.g., Media Access Control .MAC, Transmission Control Protocol/Internet Protocol .TCP/IP addresses) for device identification or organizational authentic For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.05.02.

IA-5.17 · Presentation Attack Detection for Biometric Authenticators Control Statement: Employ presentation attack detection mechanisms for biometric-based authentication. Supplemental Guidance: Employ presentation attack detection mechanisms for biometric-based authentication. Biometric characteristics do not constitute secrets. Such characteristics can be obtained by online web accesses, taking a picture of someone with a camera phone to obtain facial images with or without their knowledge, lifting from objects that someone has touched (e.g., a latent fingerprint), or capturing a high-resolution image (e.g., an iris pattern). Presentation attack detection technologies including liveness detection, can mitigate the risk of these types of attacks by making it difficult to produce artifacts intended to defeat the biometric sensor.

03.05.12 · Authenticator Management Control Statement: SR-03.05.12.a Verify the identity of the individual, group, role, service, or device receiving the authenticator as part of the initial authenticator distribution. SR-03.05.12.b Establish initial authenticator content for any authenticators issued by the organization. SR-03.05.12.c Establish and implement administrative procedures for initial authenticator distribution; for lost, compromised, or damaged authenticators; and for revoking authenticators. SR-03.05.12.d Change default authenticators at first use. SR-03.05.12.e Change or refresh authenticators [organization-defined parameter] or when the following events occur: [organization-defined parameter]. SR-03.05.12.f Protect authenticator content from unauthorized disclosure and modification. Supplemental Guidance: Authenticators include passwords, cryptographic devices, biometrics, certificates, one-time password devices, and ID badges. The initial authenticator content is the actual content of the authenticator (e.g., the initial password). In contrast, requirements for authenticator content contain specific characteristics. Authenticator management is supported by organization-defined settings and restrictions for various authenticator characteristics (e.g., password complexity and composition rules, validation time window for time synchronous one-time tokens, and the number of allowed rejections during the verification stage of biometric authentication). The requirement to protect individual authenticators may be implemented by
[(#/cppt/framework/version/SP_800_171_3_0_0/home?element=03.15.03)03.15.03 for authenticators in the possession of individuals and by
[(#/cppt/framework/version/SP_800_171_3_0_0/home?element=03.01.01) 03.01.01,
[(#/cppt/framework/version/SP_800_171_3_0_0/home?element=03.01.02) 03.01.02,
[(#/cppt/framework/version/SP_800_171_3_0_0/home?element=03.01.05)03.01.05, and
[(#/cppt/framework/version/SP_800_171_3_0_0/home?element=03.13.08)03.13.08 for authenticators stored in organizational systems. This includes passwords stored in hashed or encrypted formats or files that contain hashed or encrypted passwords that are accessible with administrator privileges.

Actions can be taken to protect authenticators, including maintaining possession of authenticators, not sharing authenticators with others, and immediately reporting lost, stolen, or compromised authenticators. Developers may deliver system components with factory default authentication credentials to allow for initial installation and configuration. Default authentication credentials are often well-known, easily discoverable, and present a significant risk. Authenticator management includes issuing and revoking authenticators for temporary access when they are no longer needed. The use of long passwords or passphrases may obviate the need to periodically change authenticators. Assessment Objectives: - the identity of the individual, group, role, service, or device receiving the authenticator as part of the initial authenticator distribution is verified. - initial authenticator content for any authenticators issued by the organization is established. - administrative procedures for initial authenticator distribution are established. - administrative procedures for lost, compromised, or damaged authenticators are established. - administrative procedures for revoking authenticators are established. - administrative procedures for initial authenticator distribution are implemented. - administrative procedures for lost, compromised, or damaged authenticators are implemented. - administrative procedures for revoking authenticators are implemented. - default authenticators are changed at first use. - authenticators are changed or refreshed [organization-defined parameter] or when the following events occur: [organization-defined parameter]. - authenticator content is protected from unauthorized disclosure. - authenticator content is protected from unauthorized modification. Organization-Defined Parameters: - A.03.05.12.ODP.01: frequency - A.03.05.12.ODP.02: events

NIST SP 800-53 Rev 5 control IA-2.1 (Multi-factor Authentication to Privileged Accounts) is assessed by examining, interviewing, and testing: IA-2.1 · Multi-factor Authentication to Privileged Accounts Control Statement: Implement multi-factor authentication for access to privileged accounts. Supplemental Guidance: Implement multi-factor authentication for access to privileged accounts. Multi-factor authentication requires the use of two or more different factors to achieve authentication. The authentication factors are defined as follows: something you know (e.g., a personal identification number [PIN]), something you have (e.g., a

NIST SP 800-53 Rev 5 control IA-12.3 (Identity Evidence Validation and Verification) summarizes the requirements for this control: IA-12.3 · Identity Evidence Validation and Verification Control Statement: Require that the presented identity evidence be validated and verified through [organization-defined parameter]. Supplemental Guidance: Require that the presented identity evidence be validated and verified through [organization-defined parameter]. Validation and verification of identity evidence increases the assurance that accounts and identifiers are being established for the correct user and authenticators are being

NIST SP 800-171 Rev 3 control 03.05.11 (03.05.11 Authentication Feedback) is assessed by examining the following: Assessment Objectives: - feedback of authentication information during the authentication process is obscured.

Under the FedRAMP High baseline, IA-5.7 (IA-5.7 No Embedded Unencrypted Static Authenticators): FedRAMP High Baseline · IA-5.7 · No Embedded Unencrypted Static Authenticators Control Statement: Ensure that unencrypted static authenticators are not embedded in applications or other forms of static storage. Supplemental Guidance: Ensure that unencrypted static authenticators are not embedded in applications or other forms of static storage. In addition to applications, other forms of static storage include access scripts and function keys. Organizations exercise caution when determining wh

Under the FedRAMP Low baseline, IA-4 (IA-4 Identifier Management): FedRAMP Low Baseline · IA-4 · Identifier Management Control Statement: Manage system identifiers by: a. Receiving authorization from [organization-defined parameter] to assign an individual, group, role, service, or device identifier; b. Selecting an identifier that identifies an individual, group, role, service, or device; c. Assigning the identifier to the intended individual, group, role, service, or device; and d. Preventing reuse of identifiers for [organization-defined parameter]. Supple

NIST SP 800-53 Rev 5 control IA-5.16 (In-person or Trusted External Party Authenticator Issuance) is assessed by examining, interviewing, and testing: IA-5.16 · In-person or Trusted External Party Authenticator Issuance Control Statement: Require that the issuance of [organization-defined parameter] be conducted [organization-defined parameter] before [organization-defined parameter]

with authorization by [organization-defined parameter]. Supplemental Guidance: Require that the issuance of [organization-defined parameter] be conducted [organization-defined parameter] before [organization-defined parameter] with authorization by [organization]

NIST SP 800-53 Rev 5 control IA-12.5 (Address Confirmation) is assessed by examining, interviewing, and testing: IA-12.5 · Address Confirmation Control Statement: Require that a [organization-defined parameter] be delivered through an out-of-band channel to verify the users address (physical or digital) of record. Supplemental Guidance: Require that a [organization-defined parameter] be delivered through an out-of-band channel to verify the users address (physical or digital) of record. To make it more difficult for adversaries to pose as legitimate users during the identity proofing process, organizatio

Under the FedRAMP Moderate baseline, IA-2.1 (IA-2.1 Multi-factor Authentication to Privileged Accounts): FedRAMP Moderate Baseline · IA-2.1 · Multi-factor Authentication to Privileged Accounts Control Statement: Implement multi-factor authentication for access to privileged accounts. Supplemental Guidance: Implement multi-factor authentication for access to privileged accounts. Multi-factor authentication requires the use of two or more different factors to achieve authentication. The authentication factors are defined as follows: something you know (e.g., a personal identification number [PIN]),

Under the FedRAMP Moderate baseline, IA-7 (IA-7 Cryptographic Module Authentication): FedRAMP Moderate Baseline · IA-7 · Cryptographic Module Authentication Control Statement: Implement mechanisms for authentication to a cryptographic module that meet the requirements of applicable laws, executive orders, directives, policies, regulations, standards, and guidelines for such authentication. Supplemental Guidance: Implement mechanisms for authentication to a cryptographic module that meet the requirements of applicable laws, executive orders, directives, policies, regulations, st

NIST SP 800-171 Rev 3 control 03.05.07 (03.05.07 Password Management) is assessed by examining the following: Assessment Objectives: - a list of commonly used, expected, or compromised passwords is maintained. - a list of commonly used, expected, or compromised passwords is updated [organization-defined parameter]. - a list of commonly used, expected, or compromised passwords is updated when organizational passwords are suspected to have been compromised. - passwords are verified not to be found on the list of commonly used, expected, or compromised passwords when they are created or updated by users. - passwords are only transmitted over cryptographically protected channels. - passwords are stored in

NIST SP 800-171 Rev 3 control 03.05.11 (03.05.11 Authentication Feedback) falls under the Identification and Authentication family. 03.05.11 · Authentication Feedback Supplemental Guidance: Authentication feedback does not provide information that would allow unauthorized individuals to compromise authentication mechanisms. For example, for desktop or notebook systems with relatively large monitors, the threat may be significant (commonly referred to as shoulder surfing). For mobile devices with small displays, this threat may be less significant and is balanced against the increased likelihood of input errors due to small Supplemental Guidance: Authentication feedback does not provide information that would allow unauthorized individuals to compromise authentication mechanisms. For example, for desktop or notebook systems with relatively large monitors, the threat may be significant (commonly referred to as shoulder surfing). For mobile devices with small displays, this threat may be less significant and is balanced against the increased likelihood of input errors due to small keyboards. Therefore, the means of o

NIST SP 800-53 Rev 5 control IA-12.5 (Address Confirmation) is defined as follows: IA-12.5 · Address Confirmation Control Statement: Require that a [organization-defined parameter] be delivered through an out-of-band channel to verify the users address (physical or digital) of record. Supplemental Guidance: Require that a [organization-defined parameter] be delivered through an out-of-band channel to verify the users address (physical or digital) of record. To make it more difficult for adversaries to pose as legitimate users during the identity proofing process, organizations can use out-of-band methods to ensure that the individual associated with an address of record is

Control IA-5(10): IA-5(11) Policy and Procedures Identification and Authentication (Organizational

Users) MULTI-FACTOR AUTHENTICATION TO PRIVILEGED ACCOUNTS MULTI-FACTOR AUTHENTICATION TO NON-PRIVILEGED ACCOUNTS LOCAL ACCESS TO PRIVILEGED ACCOUNTS LOCAL ACCESS TO NON-PRIVILEGED ACCOUNTS INDIVIDUAL AUTHENTICATION WITH GROUP AUTHENTICATION ACCESS TO ACCOUNTS · SEPARATE DEVICE · O O/S S S W: Incorporated into IA-2(1). W: Incorporated into IA-2(2). O/S S W: Incorporated into IA-2(6). NETWORK ACCESS TO NON-PRIVILEGED ACCOUNTS · SEPARATE DEVICE ACCESS TO ACCOUNTS · REPLAY RESISTANT NETWORK ACCESS TO NON-PRIVILEGED ACCOUNTS · REPLAY RESISTANT W: Incorporated into IA-2(8). SINGLE SIGN-ON REMOTE ACCESS · SEPARATE DEVICE ACCEPTANCE OF PIV CREDENTIALS OUT-OF-BAND AUTHENTICATION W: Incorporated into IA-2(6). S S S Device Identification and Authentication CRYPTOGRAPHIC BIDIRECTIONAL AUTHENTICATION S S S CRYPTOGRAPHIC BIDIRECTIONAL NETWORK AUTHENTICATION W: Incorporated into IA-3(1). DYNAMIC ADDRESS ALLOCATION DEVICE ATTESTATION Identifier Management PROHIBIT ACCOUNT IDENTIFIERS AS PUBLIC IDENTIFIERS SUPERVISOR AUTHORIZATION MULTIPLE FORMS OF CERTIFICATION IDENTIFY USER STATUS DYNAMIC MANAGEMENT CROSS-ORGANIZATION MANAGEMENT IN-PERSON REGISTRATION PAIRWISE PSEUDONYMOUS IDENTIFIERS ATTRIBUTE MAINTENANCE AND PROTECTION Authenticator Management PASSWORD-BASED AUTHENTICATION PUBLIC KEY-BASED AUTHENTICATION IN-PERSON OR TRUSTED EXTERNAL PARTY REGISTRATION AUTOMATED SUPPORT FOR PASSWORD STRENGTH DETERMINATION CHANGE AUTHENTICATORS PRIOR TO DELIVERY PROTECTION OF AUTHENTICATORS NO EMBEDDED UNENCRYPTED STATIC AUTHENTICATORS MULTIPLE SYSTEM ACCOUNTS FEDERATED CREDENTIAL MANAGEMENT DYNAMIC CREDENTIAL BINDING HARDWARE TOKEN-BASED AUTHENTICATION O O O O W: Incorporated into IA-12(1). W: Incorporated into IA-12(2). O S O W: Incorporated into IA-12(4). O O/S O/S O/S S W: Incorporated into IA-12(4). W: Incorporated into IA-5(1).

NIST SP 800-53 Rev 5 control IA-5.8 (Multiple System Accounts) summarizes the requirements for this control: IA-5.8 · Multiple System Accounts Control Statement: Implement [organization-defined parameter] to manage the risk of compromise due to individuals having accounts on multiple systems. Supplemental Guidance: Implement [organization-defined parameter] to manage the risk of compromise due to individuals having accounts on multiple systems. When individuals have accounts on multiple systems and use the same authenticators such as passwords, there is the risk that a compromise of one account may I

Under the FedRAMP High baseline, IA-2.5 (IA-2.5 Individual Authentication with Group Authentication): FedRAMP High Baseline · IA-2.5 · Individual Authentication with Group Authentication Control Statement: When shared accounts or authenticators are employed, require users to be individually authenticated before granting access to the shared accounts or resources. Supplemental Guidance: When shared accounts or authenticators are employed, require users to be individually authenticated before granting access to the shared accounts or resources. Individual authentication prior to shared group aut

Under the FedRAMP Moderate baseline, IA-2.6 (IA-2.6 Access to Accounts ·separate Device): FedRAMP Moderate Baseline · IA-2.6 · Access to Accounts ·separate Device Control Statement: Implement multi-factor authentication for [organization-defined parameter] access to [organization-defined parameter] such that: (a) One of the factors is provided by a device separate from the system gaining access; and (b) The device meets [organization-defined parameter]. Supplemental Guidance: Implement multi-factor authentication for [organization-defined parameter] access to [organization-defined

NIST SP 800-53 Rev 5 control IA-1 (Policy and Procedures) summarizes the requirements for this control: IA-1 · Policy and Procedures Control Statement: a. Develop, document, and disseminate to [organization-defined parameter]: 1. [organization-defined parameter] identification and authentication policy that: 2. Procedures to facilitate the implementation of the identification and authentication policy and the associated identification and authentication controls; b. Designate an [organization-defined parameter] to manage the development, documentation, and dissemination of the identification

IA-4.9 · Attribute Maintenance and Protection Control Statement: Maintain the attributes for each uniquely identified individual, device, or service in [organization-defined parameter]. Supplemental Guidance: Maintain the attributes for each uniquely identified individual, device, or service in [organization-defined parameter]. For each of the entities covered in [IA-2](#ia-2), [IA-3](#ia-3), [IA-8](#ia-8) , and [IA-9](#ia-9) , it is important to maintain the attributes for each authenticated entity on an ongoing basis in a central (protected) store.

NIST SP 800-53 Rev 5 control IA-5.8 (Multiple System Accounts) is assessed by examining, interviewing, and testing: IA-5.8 · Multiple System Accounts Control Statement: Implement [organization-defined parameter] to manage the risk of compromise due to individuals having accounts on multiple systems. Supplemental Guidance: Implement [organization-defined parameter] to manage the risk of compromise due to individuals having accounts on multiple systems. When individuals have accounts on multiple systems and use the same authenticators such as passwords, there is the risk that a compromise of one account may

NIST SP 800-53 Rev 5 control IA-8 (Identification and Authentication (Non-organizational Users)) summarizes the requirements for this control: IA-8 · Identification and Authentication (Non-organizational Users) Control Statement: Uniquely identify and authenticate non-organizational users or processes acting on behalf of non-organizational users. Supplemental Guidance: Uniquely identify and authenticate non-organizational users or processes acting on behalf of non-organizational users. Non-organizational users include system users other than organizational users explicitly covered by [IA-2](#ia-2) . Non-organizational users are unique

and 2. Procedures [Assignment: organization-defined frequency] and following [Assignment: organization-defined events]. Discussion: Identification and authentication policy and procedures address the controls in the IA family that are implemented within systems and organizations. The risk management strategy is an important factor in establishing such policies and procedures. Policies and procedures contribute to security and privacy assurance. Therefore, it is important that security and privacy programs collaborate on the development of identification and authentication policy and procedures. Security and privacy program policies and procedures at the organization level are preferable, in general, and may obviate the need for mission- or system-specific policies and procedures.

NIST SP 800-171 Rev 3 control 03.05.03 (03.05.03 Multi-Factor Authentication) is assessed by examining the following: Assessment Objectives: - multi-factor authentication for access to privileged accounts is implemented. - multi-factor authentication for access to non-privileged accounts is implemented.

NIST SP 800-171 Rev 3 control 03.05.11 (03.05.11 Authentication Feedback) requires organizations to implement the following: 03.05.11 · Authentication Feedback Supplemental Guidance: Authentication feedback does not provide information that would allow unauthorized individuals to compromise authentication mechanisms. For example, for desktop or notebook systems with relatively large monitors, the threat may be significant (commonly referred to as shoulder surfing). For mobile devices with small displays, this threat may be less significant and is balanced against the increased likelihood of input errors due to small For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.05.11.

Under the FedRAMP High baseline, IA-5 (IA-5 Authenticator Management): FedRAMP High Baseline · IA-5 · Authenticator Management Control Statement: Manage system authenticators by: a. Verifying, as part of the initial authenticator distribution, the identity of the individual, group, role, service, or device receiving the authenticator; b. Establishing initial authenticator content for any authenticators issued by the organization; c. Ensuring that authenticators have sufficient strength of mechanism for their intended use; d. Establishing and implementing administrative

NIST SP 800-53 Rev 5 control IA-5.16 (In-person or Trusted External Party Authenticator Issuance) summarizes the requirements for this control: IA-5.16 · In-person or Trusted External Party Authenticator Issuance Control Statement: Require that the issuance of [organization-defined parameter] be conducted [organization-defined parameter] before [organization-defined parameter] with authorization by [organization-defined parameter]. Supplemental Guidance: Require that the issuance of [organization-defined parameter] be conducted [organization-defined parameter] before [organization-defined parameter] with authorization by [organization-defined parameter]

NIST SP 800-53 Rev 5 control IA-3.4 (Device Attestation) is defined as follows: IA-3.4 · Device Attestation Control Statement: Handle device identification and authentication based on attestation by [organization-defined parameter]. Supplemental Guidance: Handle device identification and authentication based on attestation by [organization-defined parameter]. Device attestation refers

to the identification and authentication of a device based on its configuration and known operating state. Device attestation can be determined via a cryptographic hash of the device. If device attestation is the means of identification and authentication, then it is important that patches

NIST SP 800-171 Rev 3 control 03.05.05 (03.05.05 Identifier Management) is assessed by examining the following: Assessment Objectives: - authorization is received from organizational personnel or roles to assign an individual, group, role, service, or device identifier. - an identifier that identifies an individual, group, role, service, or device is selected. - an identifier that identifies an individual, group, role, service, or device is assigned. - the reuse of identifiers for [organization-defined parameter] is prevented. - individual identifiers are managed by uniquely identifying each individual as [organization-defined parameter].

NIST SP 800-53 Rev 5 control IA-5.17 (Presentation Attack Detection for Biometric Authenticators) is assessed by examining, interviewing, and testing: IA-5.17 · Presentation Attack Detection for Biometric Authenticators Control Statement: Employ presentation attack detection mechanisms for biometric-based authentication. Supplemental Guidance: Employ presentation attack detection mechanisms for biometric-based authentication. Biometric characteristics do not constitute secrets. Such characteristics can be obtained by online web accesses, taking a picture of someone with a camera phone to obtain facial images with or without their knowledge,

NIST SP 800-53 Rev 5 control IA-5.6 (Protection of Authenticators) summarizes the requirements for this control: IA-5.6 · Protection of Authenticators Control Statement: Protect authenticators commensurate with the security category of the information to which use of the authenticator permits access. Supplemental Guidance: Protect authenticators commensurate with the security category of the information to which use of the authenticator permits access. For systems that contain multiple security categories of information without reliable physical or logical separation between categories, authenticators us

NIST SP 800-53 Rev 5 control IA-3.3 (Dynamic Address Allocation): IA-3.3 · Dynamic Address Allocation Control Statement: (a) Where addresses are allocated dynamically, standardize dynamic address allocation lease information and the lease duration assigned to devices in accordance with [organization-defined parameter] ; and (b) Audit lease information when assigned to a device. Supplemental Guidance: (a) Where addresses are allocated dynamically, standardize d

NIST SP 800-171 Rev 3 control 03.05.04 (03.05.04 Replay-Resistant Authentication) maps to corresponding controls in NIST SP 800-53 Rev 5 under the Identification and Authentication (IA) family. The CMMC Level 2 assessment guide provides the specific mapping. Organizations implementing both frameworks should use the NIST SP 800-171 Rev 3 to SP 800-53 Rev 5 crosswalk to identify overlapping controls and avoid duplicate effort.

NIST SP 800-53 Rev 5 control IA-4.8 (Pairwise Pseudonymous Identifiers) is assessed by examining, interviewing, and testing: IA-4.8 · Pairwise Pseudonymous Identifiers Control Statement: Generate pairwise pseudonymous identifiers. Supplemental Guidance: Generate pairwise pseudonymous identifiers. A pairwise pseudonymous identifier is an opaque unguessable subscriber identifier generated by an identity provider for use at a specific individual relying party. Generating distinct pairwise pseudonymous identifiers with no identifying information about a subscriber discourages subscriber activity tracking and profiling b

NIST SP 800-53 Rev 5 control IA-13.1 (Protection of Cryptographic Keys) is defined as follows: IA-13.1 · Protection of Cryptographic Keys Control Statement: Cryptographic keys that protect access tokens are generated, managed, and protected from disclosure and misuse. Supplemental Guidance: Cryptographic keys that protect access tokens are generated, managed, and protected from disclosure and misuse. Identity assertions and access tokens are typically digitally signed. The private keys used to sign these assertions and tokens are protected commensurate with the impact of the system and information resources that can be accessed.

NIST SP 800-53 Rev 5 control IA-5.6 (Protection of Authenticators): IA-5.6 · Protection of Authenticators Control Statement: Protect authenticators commensurate with the security category of the information to which use of the authenticator permits access. Supplemental Guidance: Protect authenticators commensurate with the security category of the information to which use of the

authenticator permits access. For systems that contain multiple security categories

NIST SP 800-171 Rev 3 control 03.05.12 (03.05.12 Authenticator Management) is assessed by examining the following: Assessment Objectives: - the identity of the individual, group, role, service, or device receiving the authenticator as part of the initial authenticator distribution is verified. - initial authenticator content for any authenticators issued by the organization is established. - administrative procedures for initial authenticator distribution are established. - administrative procedures for lost, compromised, or damaged authenticators are established. - administrative procedures for revoking authenticators are established. - administrative procedures for initial authenticator distribution are

NIST SP 800-171 Rev 3 control 03.05.11 (03.05.11 Authentication Feedback) is assessed by examining the following: Assessment Objectives: - feedback of authentication information during the authentication process is obscured.

NIST SP 800-53 Rev 5 control IA-12.1 (Supervisor Authorization) is assessed by examining, interviewing, and testing: IA-12.1 · Supervisor Authorization Control Statement: Require that the registration process to receive an account for logical access includes supervisor or sponsor authorization. Supplemental Guidance: Require that the registration process to receive an account for logical access includes supervisor or sponsor authorization. Including supervisor or sponsor authorization as part of the registration process provides an additional level of scrutiny to ensure that the user's management chain is aware

NIST SP 800-53 Rev 5 control IA-2.1 (Multi-factor Authentication to Privileged Accounts) summarizes the requirements for this control: IA-2.1 · Multi-factor Authentication to Privileged Accounts Control Statement: Implement multi-factor authentication for access to privileged accounts. Supplemental Guidance: Implement multi-factor authentication for access to privileged accounts. Multi-factor authentication requires the use of two or more different factors to achieve authentication. The authentication factors are defined as follows: something you know (e.g., a personal identification number [PIN]), something you have (e.g., a

NIST SP 800-53 Rev 5 control IA-13.3 (Token Management) is assessed by examining, interviewing, and testing: IA-13.3 · Token Management Control Statement: In accordance with [organization-defined parameter], assertions and access tokens are: (a) generated; (b) issued; (c) refreshed; (d) revoked; (e) time-restricted; and (f) audience-restricted. Supplemental Guidance: In accordance with [organization-defined parameter], assertions and access tokens are: (a) generated; (b) issued; (c) refreshed; (d) revoked; (e) time-restricted; and (f) audience-restricted. An access token is a piece of data that repre

Control IA-4: HREE PAGE 136 This publication is available free of charge from: <https://doi.org/10.6028/NIST.SP.800-53r5>. NIST

SP 800-53, REV. 5 SECURITY AND PRIVACY CONTROLS FOR INFORMATION SYSTEMS AND ORGANIZATIONS

messaging. Prohibiting the use of systems account identifiers that are the same as some public identifier, such as the individual identifier section of an electronic mail address, makes it more difficult for adversaries to guess user identifiers. Prohibiting account identifiers as public identifiers without the implementation of other supporting controls only complicates guessing of identifiers. Additional protections are required for authenticators and credentials to protect the account. Related Controls: AT-2, PT-7. (2) IDENTIFIER MANAGEMENT | SUPERVISOR AUTHORIZATION [Withdrawn: Incorporated into IA-12(1).] (3) IDENTIFIER MANAGEMENT | MULTIPLE FORMS OF CERTIFICATION [Withdrawn: Incorporated into IA-12(2).] (4) IDENTIFIER MANAGEMENT | IDENTIFY USER STATUS Manage individual identifiers by uniquely identifying each individual as [Assignment: organization-defined characteristic identifying individual status]. Discussion: Characteristics that identify the status of individuals include contractors, foreign nationals, and non-organizational users. Identifying the status of individuals by these characteristics provides additional information about the people with whom organizational personnel are communicating. For example, it might be useful for a government employee to know that one of the individuals on an email message is a contractor. Related Controls: None.

NIST SP 800-53 Rev 5 control IA-2.5 (Individual Authentication with Group Authentication) is defined

as follows: IA-2.5 · Individual Authentication with Group Authentication Control Statement: When shared accounts or authenticators are employed, require users to be individually authenticated before granting access to the shared accounts or resources. Supplemental Guidance: When shared accounts or authenticators are employed, require users to be individually authenticated before granting access to the shared accounts or resources. Individual authentication prior to shared group authentication mitigates the risk of using group accounts or authenticators.

NIST SP 800-171 Rev 3 control 03.05.05 (03.05.05 Identifier Management) requires organizations to implement the following: Control Statement: SR-03.05.05.a Receive authorization from organizational personnel or roles to assign an individual, group, role, service, or device identifier. SR-03.05.05.b Select and assign an identifier that identifies an individual, group, role, service, or device. SR-03.05.05.c Prevent the reuse of identifiers for [organization-defined parameter]. SR-03.05.05.d Manage individual identifiers by uniquely identifying each individual as [organization-defined parameter]. For practical implementation, organizations should document their approach in their System Security Plan (SSP) and ensure that policies, procedures, and technical controls address each sub-requirement of 03.05.05.

NIST SP 800-53 Rev 5 control IA-3 (Device Identification and Authentication) is assessed by examining, interviewing, and testing: IA-3 · Device Identification and Authentication Control Statement: Uniquely identify and authenticate [organization-defined parameter] before establishing a [organization-defined parameter] connection. Supplemental Guidance: Uniquely identify and authenticate [organization-defined parameter] before establishing a [organization-defined parameter] connection. Devices that require unique device-to-device identification and authentication are defined by type, device, or a combination of type and d

NIST SP 800-171 Rev 3 control 03.05.01 (03.05.01 User Identification and Authentication) falls under the Identification and Authentication family. Control Statement: SR-03.05.01.a Uniquely identify and authenticate system users, and associate that unique identification with processes acting on behalf of those users. SR-03.05.01.b Re-authenticate users when [organization-defined parameter] . Supplemental Guidance: System users include individuals (or system processes acting on behalf of individuals) who are authorized to access a system. Typically, individual identifiers are the usernames associated with the system accounts assigned to those individuals. Since system processes execute on behalf of groups and roles, organizations may require the unique identification of individuals in group accounts or the accountability of individual activity. The unique identification and authentic

NIST SP 800-53 Rev 5 control IA-5.2 (Public Key-based Authentication) summarizes the requirements for this control: IA-5.2 · Public Key-based Authentication Control Statement: (a) For public key-based authentication: (1) Enforce authorized access to the corresponding private key; and (2) Map the authenticated identity to the account of the individual or group; and (b) When public key infrastructure (PKI) is used: (1) Validate certificates by constructing and verifying a certification path to an accepted trust anchor, including checking certificate status information; and (2) Implement a local cache o

Under the FedRAMP Moderate baseline, IA-2.2 (IA-2.2 Multi-factor Authentication to Non-privileged Accounts): FedRAMP Moderate Baseline · IA-2.2 · Multi-factor Authentication to Non-privileged Accounts Control Statement: Implement multi-factor authentication for access to non-privileged accounts. Supplemental Guidance: Implement multi-factor authentication for access to non-privileged accounts. Multi-factor authentication requires the use of two or more different factors to achieve authentication. The authentication factors are defined as follows: something you know (e.g., a personal identification nu